TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

APT flaw lets a network attacker swap verified packages and run code as root on Debian and Ubuntu

From **Cybersecurity Briefing** · 2026-11-04 to 2026-11-05 (last 24 hours; Indiana sections swept back to the 2026-10-31 cutoff) · Briefing generated 2026-11-05

REPORT ID	VERSION	HANDLING
CTI-20261105-01	1.0 · 2026-11-05 08:08 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-11-04	2026-11-05
CVES	**ANALYST**	
CVE-2026-109518 (CVSS 7.7)	Nick Sturgeon	

VULNERABILITY | HIGH | PATCH AVAILABLE | OVERALL CONFIDENCE: HIGH

BOTTOM LINE UP FRONT

CVE-2026-109518 is a file verification bypass in APT, the package manager used by Debian, Ubuntu and their derivatives. An attacker who can alter HTTP traffic between a client and a package server, including a malicious mirror or proxy, can get APT to install a package it never verified. Package install scripts run as root, so the result is root code execution [S2] [S3] [S8]. The flaw was found by Max Justicz, and the fix was written by APT maintainer Julian Andres Klode [S2] [S10]. Ubuntu scores it 7.7 (CVSS 4.0, High), while the APT developers label it critical [S2] [S3].

The bug combines two conditions. An HTTP redirect can make two different package downloads share one destination file, and a forced retry then writes attacker data through a hard link into a file APT has already checked [S3] [S4] [S10]. Exposure requires a non-zero Acquire::Retries setting. It has been non-zero by default since APT 2.3.2, with a default of 3 on Debian 12 and Ubuntu 22.04 and later. Older releases are exposed only if a script or configuration turned retries on [S2] [S3]. The attack starts only when a package install takes place [S2]. Ubuntu says snaps and non-HTTP transports such as FTP are not affected [S8].

Fixes are out. Debian 13 has apt 3.0.4, Debian 12 has 2.6.2, and Debian unstable has 3.3.6 [S4] [S5] [S9]. Ubuntu has shipped fixes for all eight tracked releases from 14.04 to 26.10, though 20.04 and older need Ubuntu Pro, and 16.04 and 14.04 also need the Legacy Support add-on [S6]. No exploitation has been reported, CISA's assessment records exploitation as none and automation as not possible, and the CVE is

not in the KEV catalog [S2] [S13]. FIRST returned no EPSS score as of 2026-11-05 [S14]. No atomic indicators of compromise have been published by any source reviewed [S8] [S15] [S16].

Update the apt package on every Debian and Ubuntu host and image, starting with systems that use third-party mirrors, proxies or plain HTTP sources. The update is itself fetched by the vulnerable APT, so run it with retries disabled, using the -o Acquire::Retries=0 option Ubuntu recommends [S8]. This corrects the briefing excerpt, which said no workaround was listed. Debian's and the APT developers' advisories name none [S3] [S4], but Ubuntu's later guidance supports both temporary retry disabling and moving to HTTPS sources [S8]. HTTPS blocks a third party on the network path. In our assessment it does not stop a malicious mirror that serves the content itself, so HTTPS does not replace the patch.

Key judgments

UNLIKELY · MODERATE CONFIDENCE
Widespread opportunistic exploitation of CVE-2026-109518 within the next 30 days is unlikely. The attacker needs a position on the network path or control of a mirror or proxy, a victim install must occur, CISA rates the flaw as not automatable, and unattended upgrades should close much of the default Ubuntu exposure quickly. [S2] [S8] [S13]

LIKELY · MODERATE CONFIDENCE
Public technical detail or working proof-of-concept code will likely appear within 30 days. The fix commit and its integration test are public and describe the failing behavior, and the finder has a record of APT research, which lowers the effort needed to reproduce the flaw. [S3] [S10] [S15] [S17]

VERY LIKELY · MODERATE CONFIDENCE
Vulnerable APT versions will very likely persist for weeks in container base images, golden images, end-of-support releases and derivative distributions, even after directly managed hosts are patched. Ubuntu's older releases require paid support tiers, Debian 11 is out of standard LTS support, and downstream distributions were not named. [S1] [S6] [S8] [S16]

LIKELY · LOW CONFIDENCE
If exploitation occurs, it will likely be targeted and may go unnoticed, focused on compromised mirrors, caching proxies or hostile network segments. A swapped package can look internally consistent on the host, and no signatures or indicators exist yet. [S15] [S16]

INDICATORS OF COMPROMISE

No source reviewed publishes atomic indicators such as IPs, domains or hashes, because no exploitation has been reported. Every entry below is a behavior, configuration condition or hunting location, taken from vendor advisories and two lower-graded analyses or derived by the analyst as of 2026-11-05, and most will also match legitimate APT activity.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Acquire::Retries set to a non-zero value`	Required condition for exploitation, not evidence of compromise. Default is 3 on Debian 12 and Ubuntu 22.04 and later; check older releases for scripts or configuration that enable it.	REPORTED		[S2] [S3]
user-agent	`APT-HTTP`	APT client user agent token. Use it in proxy logs to find clients reporting a version below the fixed release and clients fetching over plain HTTP. It marks normal APT traffic, so it is an inventory and hunting pivot only.	REPORTED		[S16]
http-request	`Repeated GET requests for .deb files from one client that include redirects and 5xx responses within minutes`	Traffic pattern matching the redirect and retry sequence. Transient mirror errors produce the same pattern, so treat it as a lead.	REPORTED		[S3] [S16]
http-request	`APT requests to hosts outside the approved mirror list`	Possible malicious mirror, unapproved proxy or redirect to an attacker-controlled host. Requires a maintained allowlist, including internal mirrors and caches.	REPORTED		[S16]
filepath	`/var/lib/dpkg/info/`	Package maintainer scripts. Review for scripts that start downloaders, decoders or reverse shells.	REPORTED		[S16]
filepath	`/etc/apt/sources.list`	Package source definition. Check for plain http:// entries and unapproved mirrors.	REPORTED		[S8]
filepath	`/etc/apt/sources.list.d/`	Additional package source definitions in .list or .sources format. Check for plain http:// entries and unapproved mirrors.	REPORTED		[S8]
filepath	`/etc/apt/apt.conf.d/`	Sources describe a configuration drop-in for the retry setting but S11 gives no path; this is the standard APT drop-in directory. Check it for Acquire::Retries overrides on older releases and for Acquire::http::Proxy settings that point to unapproved proxies.	DERIVED		[S11] [S15]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/var/cache/apt/archives/`	S16 advises comparing cached .deb files against SHA256 values in the signed index but names no path; this is APT's standard cache location. An empty cache proves nothing.	DERIVED		[S16]
filepath	`/var/log/apt/history.log`	S16 notes that APT and dpkg logs are local files that must be collected separately; this is the standard APT history path. Use it to establish which packages were installed during the exposure window.	DERIVED		[S16]
filepath	`/var/log/dpkg.log`	Standard dpkg log path, derived from the same S16 guidance. Use it to correlate off-hours or unexpected installs with network activity.	DERIVED		[S16]
command	`dpkg maintainer script under /var/lib/dpkg/info/ spawning curl, wget, base64, nc or an interactive shell`	S16 reports downloaders, decoders and reverse shells in maintainer scripts as a behavior to review. The specific tool names are the analyst's examples. Some legitimate packages download data during install, so baseline first.	DERIVED		[S16]
other	`Public network connections made by processes running under dpkg`	Behavioral lead for a malicious maintainer script. Some legitimate packages also do this.	REPORTED		[S16]
other	`Binaries written by dpkg with low global prevalence`	Lead for a swapped package. Internal and locally rebuilt packages will also match.	REPORTED		[S16]
other	`Installed package checksum differs from the official archive copy of the same version, or the installed version is absent from the archive candidate list`	Compare against a copy fetched over HTTPS. A lead, not proof, because local rebuilds also differ. dpkg --verify is not sufficient because a tampered package carries its own checksums.	REPORTED		[S15] [S16]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
port	`80/tcp`	The attack path relies on plain HTTP package traffic, and port 80 is the default HTTP port. Use outbound APT traffic on this port to find exposed clients; HTTP on other ports is also possible.	DERIVED		[S2] [S8]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

No real-world attack has been reported, so this describes the attack path from the advisories and the fix. An attacker able to alter HTTP traffic, or running a malicious mirror or proxy, waits for a package install. A redirect makes two separate package downloads resolve to the same URI, so APT merges them and hard-links their destination. The attacker then returns a transient server error to force a retry. When the download resumes, APT opens the existing file without an exclusive flag and writes through the hard link into a package that has already passed verification. dpkg installs the altered file and its maintainer scripts run as root [S3] [S4] [S10] [S15]. The fix makes APT create destination files exclusively and copy partial data into a new file before hashing [S10]. The ATT&CK mapping below is the analyst's and describes potential procedures, not observed activity.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Collection	T1557 Adversary-in-the-Middle	The attacker sits on the network path, or operates a malicious mirror or proxy, and manipulates HTTP traffic between the APT client and the archive. [S2] [S8]	Inventory APT clients that use plain HTTP and flag requests to hosts outside the approved mirror list.
Impact	T1565.002 Data Manipulation: Transmitted Data Manipulation	The attacker uses HTTP redirects and transient server errors to force a retry, then supplies a chosen payload during the resumed download. [S3] [S4] [S16]	Hunt proxy logs for one client requesting .deb files with redirects and 5xx responses within minutes.
Initial Access	T1195.002 Supply Chain Compromise: Compromise Software Supply Chain	The altered package is delivered through the host's normal software update channel in place of the requested package. [S15] [S16]	Compare cached .deb files with SHA256 values in the signed index and compare installed package checksums with official archive copies.

Tactic	Technique	Procedure observed	Detection opportunity
Defense Evasion	T1553 Subvert Trust Controls	Replacing the file after verification, through hard link reuse, defeats APT's check that the package matches the signed archive metadata. [S2] [S3] [S16]	Check the installed apt version against the fixed version for the release. Host-side detection of the swap itself is weak because dpkg --verify relies on the package's own checksums.
Privilege Escalation	T1546.016 Event Triggered Execution: Installer Packages	Maintainer scripts in the swapped .deb run as root when dpkg installs it. [S3] [S8] [S16]	Review scripts in /var/lib/dpkg/info/ and alert on maintainer scripts that spawn downloaders, decoders or shells.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	Package install scripts execute shell commands with root privileges, giving the attacker arbitrary code execution. [S8] [S16]	Alert on public network connections from processes running under dpkg, and on off-hours package installs.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

APT .deb downloads with redirects and server errors from one client `SPLUNK SPL`

```
index=proxy http_user_agent="*APT-HTTP*" url="*.deb*"
| eval class=case(status>=300 AND status<400,"redirect", status>=500,"server_error", status>=200 AND status<300,"success")
| bin _time span=10m
| stats count(eval(class="redirect")) as redirects count(eval(class="server_error")) as server_errors values(dest) as dests values(http_user_agent) as agents by _time src
| where redirects>0 AND server_errors>0
```

Index and field names depend on your proxy schema. Only visible for plain HTTP or inspected TLS traffic. Mirror outages produce false positives, so compare against other clients using the same mirror.

Plain HTTP APT traffic leaving the network `SURICATA`

```
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"POLICY APT client fetching package over plain HTTP"; flow:established,to_server; http.user_agent; content:"APT-HTTP"; http.uri; content:".deb"; endswith; threshold:type limit, track by_src, count 1, seconds 3600; classtype:policy-violation; sid:9109518; rev:1;)
```

An exposure-finding rule, not an exploit signature. It finds clients still exposed to on-path tampering. Change the sid to fit your local range, and exclude approved internal mirrors if they sit outside $HOME_NET.

dpkg maintainer script spawns downloader, decoder or network tool `SIGMA`

```
title: Suspicious Child Process of dpkg Maintainer Script
status: experimental
logsource:
  product: linux
  category: process_creation
detection:
  selection_parent:
    ParentCommandLine|contains: '/var/lib/dpkg/info/'
  selection_child:
    Image|endswith:
      - '/curl'
      - '/wget'
      - '/base64'
      - '/nc'
      - '/ncat'
      - '/socat'
  condition: selection_parent and selection_child
falsepositives:
  - Packages that legitimately fetch or decode data during install
level: medium
```

Needs process telemetry such as auditd or an EDR. Baseline against normal patch windows and known vendor packages. Works regardless of how the package reached the host.

Public network connections during package installs `KQL`

```
DeviceNetworkEvents
| where Timestamp > ago(14d)
| where RemoteIPType == "Public"
| where InitiatingProcessCommandLine has "/var/lib/dpkg/info/"
    or InitiatingProcessParentFileName in~ ("dpkg", "dpkg-preconfigure")
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, RemoteIP,
RemoteUrl, RemotePort
| order by Timestamp desc
```

Written for Microsoft Defender for Endpoint on Linux. Short-lived scripts may be missed. Expect some legitimate matches from packages that contact vendor services during install.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
APT on Ubuntu 26.10	3.3.x below 3.3.3ubuntu0.1; exposed by default	3.3.3ubuntu0.1	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A
APT on Ubuntu 26.04 LTS	3.2.x below 3.2.1ubuntu0.1; exposed by default	3.2.1ubuntu0.1	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A
APT on Ubuntu 24.04 LTS	2.8.x below 2.8.4ubuntu0.1; exposed by default	2.8.4ubuntu0.1	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A
APT on Ubuntu 22.04 LTS	2.4.x below 2.4.15ubuntu0.1; exposed by default	2.4.15ubuntu0.1	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A
APT on Ubuntu 20.04 LTS	2.0.x below 2.0.12+esm1; exposed only if Acquire::Retries is non-zero	2.0.12+esm1 (Ubuntu Pro)	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A
APT on Ubuntu 18.04 LTS	1.6.x below 1.6.19+esm1; exposed only if Acquire::Retries is non-zero	1.6.19+esm1 (Ubuntu Pro)	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
APT on Ubuntu 16.04 LTS	1.2.x below 1.2.36+esm1; exposed only if Acquire::Retries is non-zero	1.2.36+esm1 (Ubuntu Pro with Legacy Support add-on)	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A
APT on Ubuntu 14.04 LTS	Below 1.0.1ubuntu2.24+esm4; exposed only if Acquire::Retries is non-zero	1.0.1ubuntu2.24+esm4 (Ubuntu Pro with Legacy Support add-on)	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A
APT on Debian 13 (trixie)	3.0.x below 3.0.4; exposed by default	3.0.4 (DSA-6607-1)	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A
APT on Debian 12 (bookworm)	2.6.x below 2.6.2; exposed by default	2.6.2 (DLA-4880-1)	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A
APT on Debian 11 (bullseye)	2.2.x below 2.2.5; exposed only if Acquire::Retries is non-zero	Upstream 2.2.5. The Debian tracker does not list a bullseye package; Extended LTS availability is unconfirmed	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A
APT on Debian forky (testing) and sid (unstable)	3.3.x below 3.3.6; exposed by default	3.3.6	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A
Derivative distributions based on Debian or Ubuntu	Reported as affected, but not named by the vendors	Unknown; check each distribution's advisory	CVE-2026-109518	7.7 (CVSS 4.0)	No score returned by FIRST on 2026-11-05	No	N/A

Immediate (0–24 hours)

- Update apt on all Debian and Ubuntu hosts with retries disabled for that run, because the update itself passes through the vulnerable download path. Ubuntu gives: sudo apt update && sudo apt upgrade -o Acquire::Retries=0. To update APT alone, use the --only-upgrade form in its guidance. Use a trusted network path. `IT OPS` [S8] [S16]
- Patch first where the risk is highest: hosts using third-party mirrors, proxies, plain HTTP sources or untrusted networks. `IT OPS` [S2] [S16]
- Verify results against the fixed version for each host's own release branch, not across branches. Ubuntu's check is: apt list --installed '?source-package(^apt$)'. Do not rely on unattended-upgrades alone; Ubuntu expects it to apply fixes within about 24 hours only where it is enabled. `IT OPS` [S6] [S8]
- Run apt-config dump across the fleet to find non-zero Acquire::Retries values, including on Debian 11, Ubuntu 20.04 and older releases, where scripts may have enabled it. `IT OPS` [S3] [S15]
- Start proxy log hunting for APT clients on plain HTTP, unapproved mirror destinations, and .deb downloads with redirects and 5xx responses. `SOC` [S16]

Short term (1–7 days)

- Rebuild container base images, golden images and AMIs on fixed apt, and add an apt version check to image pipelines. Update CI runners that install packages during builds. `IT OPS` [S16]
- Update apt on internal mirrors and caching proxies, move their upstream connections to HTTPS, and restrict administrative access to them. `IT OPS` [S16]
- Move package sources to HTTPS where supported, in both .list and .sources files, then run apt update and check for errors, since some community and country-specific mirrors lack HTTPS. `IT OPS` [S8]
- Identify hosts on Ubuntu 20.04 and older and on Debian 11. Enable Ubuntu Pro and Legacy Support where needed, confirm Debian 11 support options, and check derivative distributions and Linux-based appliances for vendor advisories. `IT OPS` [S1] [S6]
- For packages installed over HTTP during the exposure window on priority hosts, compare cached .deb files with SHA256 values in the signed index and compare installed packages with official HTTPS copies. Do not rely on dpkg --verify. If an unexplained mismatch appears, treat the host as possibly compromised, rebuild it from a trusted image and rotate the credentials it held. `SOC` [S15] [S16]
- Remove temporary Acquire::Retries overrides once hosts are patched, unless there is a documented reason to keep them. `IT OPS` [S8] [S15]

Long term

- Keep HTTPS as the standard for package sources and restrict outbound package traffic to an approved mirror list, as added protection beyond archive signing. `IT OPS` [S8] [S16]
- Forward APT and dpkg logs to the SIEM. They are local files by default and otherwise unavailable for investigations. `SOC` [S16]
- Fund the retirement of end-of-support Debian and Ubuntu releases, or paid extended support where retirement is not possible, and track this as a recorded risk. `LEADERSHIP` [S1] [S6]

Workarounds & compensating controls

- If a host cannot be patched yet, set Acquire::Retries to 0 in an APT configuration drop-in. This removes the retry the attack depends on, but installs may fail on transient mirror errors and the underlying flaw remains. `IT OPS` [S8] [S11] [S15]
- Use HTTPS sources to block third-party tampering on the network path. Do not count on this against a malicious mirror or an intercepting proxy trusted by the host, and do not treat it as a replacement for the fixed package. `IT OPS` [S8] [S15]
- Until patched, install packages only from trusted mirrors over trusted network paths, and avoid package operations on guest, public or shared networks. `IT OPS` [S2] [S8]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Debian and Ubuntu APT Flaw Lets MitM Attackers Swap Verified Packages and Run Code as Root
Published 2026-11-04 · `B2` Usually reliable, probably true
Briefing source. Status snapshot from mid-day 2026-11-04, partly superseded by later vendor updates.

[S2] CVE Program (Canonical CNA, CISA ADP): CVE-2026-109518: APT RCE via hard link reuse
Published 2026-11-04 · `A1` Completely reliable, confirmed by other sources
Primary record. Updated 2026-11-05. Holds affected ranges, CVSS, CWE-62 and CWE-367, and CISA SSVC values.

[S3] APT developers (Julian Andres Klode): APT-2026-11-01 security update
Published 2026-11-04 · `A1` Completely reliable, confirmed by other sources
Maintainer advisory. Rates the flaw critical and lists bundled fixes, excluded issues and upstream fixed versions.

[S4] Debian: DSA-6607-1: apt security update
Published 2026-11-04 · `A1` Completely reliable, confirmed by other sources
Vendor advisory for Debian 13.

[S5] Debian LTS: DLA-4880-1: apt security update
Published 2026-11-04 · `A1` Completely reliable, confirmed by other sources
Vendor advisory for Debian 12.

[S6] Canonical: USN-8996-1: APT vulnerability
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Vendor advisory with fixed versions for eight Ubuntu releases.

[S8] Canonical (Luci Stanescu): CVE-2026-109518 APT vulnerability fixes available
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Vendor guidance. Primary source for the retry and HTTPS mitigations and the scope exclusions.

[S9] Debian Security Tracker: CVE-2026-109518
Published · **A1** Completely reliable, confirmed by other sources
Live tracker, read 2026-11-05. Shows forky and sid fixed in 3.3.6 and lists no bullseye entry.

[S10] Debian APT team (Salsa): Commit 5af16a8a: open target files exclusively
Published · **A1** Completely reliable, confirmed by other sources
Primary fix commit, dated October 2026 with no exact day recorded. Used for root cause only.

[S11] oss-security (Jan Schaumann): CVE-2026-109518: RCE in apt(1) (DSA 6607-1)
Published 2026-11-04 · **B2** Usually reliable, probably true
Community relay of the Debian advisory. States that retries set to 0 may mitigate; later supported by S8.

[S12] NIST NVD: CVE-2026-109518 (API record)
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Status Received, modified 2026-11-05. No separate NVD score; carries Canonical's CVSS.

[S13] CISA: Known Exploited Vulnerabilities catalog, version 2026.11.04
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
The feed is ordered newest first; the top entries, down through additions dated 2026-11-04, do not include this CVE.

[S14] FIRST: EPSS API query for CVE-2026-109518
Published 2026-11-05 · **A6** Completely reliable, truth cannot be judged
Returned no data when read on 2026-11-05, so no score can be judged. Date is the access date.

[S15] Ostorlab: APT Package-Swap RCE as Root on Debian and Ubuntu (CVE-2026-109518)
Published 2026-11-05 · **C2** Fairly reliable, probably true
Secondary technical analysis consistent with S10. Source of the checksum-comparison lead.

[S16] ThreatDefence: CVE-2026-109518 Debian and Ubuntu APT: Patching, Hunting
Published 2026-11-05 · **C3** Fairly reliable, possibly true
Hunting guidance built by the vendor from the advisories, not from observed attacks. Forky status is out of date compared with S9.

[S17] Hardware Busters: APT Vulnerability Let Network Attackers Swap Verified Packages and Run Code as Root
Published 2026-11-05 · `C3` Fairly reliable, possibly true
Secondary report. Used only for the link between the finder and CVE-2019-3462 and for its no-PoC statement.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-10-12	CVE-2026-109518 reserved by Canonical.	[S2]
2026-11-04	APT developers publish APT-2026-11-01. Debian issues DSA-6607-1 for Debian 13 and DLA-4880-1 for Debian 12.	[S3] [S4] [S5]
2026-11-04	Ubuntu fixes appear in the security archive at 14:25 UTC. At 14:58 UTC Debian testing is still on 3.3.5, and at 15:46 UTC Ubuntu's CVE page still lists all eight releases as vulnerable.	[S1]
2026-11-04	CVE record published. Canonical issues USN-8996-1 and remediation guidance covering 14.04 through 26.10.	[S2] [S6] [S8]
2026-11-04	CISA KEV catalog version 2026.11.04 released without this CVE.	[S13]
2026-11-05	CVE record and NVD entry updated. The Debian tracker shows forky and sid fixed in 3.3.6. Secondary sources report no public proof of concept or exploitation.	[S2] [S9] [S12] [S15]

Relevance to Indianapolis, Indiana & managed clients

No reporting ties this flaw to Indianapolis or Indiana organizations, and no Indiana-specific exploitation is known. The practical exposure is still broad, because Ubuntu and Debian commonly underpin web servers, cloud workloads, containers and CI systems in state and local government, hospital and clinic IT, universities and K-12 districts, manufacturers and small and mid-size businesses. Universities and larger agencies that run internal mirrors or caching proxies should treat those systems as priorities, since one compromised mirror or proxy could reach many hosts. Manufacturers and healthcare organizations should ask vendors about Linux-based appliances and gateways they cannot patch themselves, and small businesses should confirm that unattended upgrades are actually running. For managed IT service clients, the main concerns are shared caching proxies, golden images and scheduled patch jobs. Scheduled jobs on unpatched hosts start the same package installs the attack needs, so providers should patch shared mirrors and proxies first, run client updates with retries disabled, confirm versions by report, and identify any client on an end-of-support release that needs paid extended support.

Intelligence gaps

- No technical write-up from the finder was located, and no public proof of concept was confirmed. Watch for one, since it would raise the priority of any remaining unpatched systems.
- No exploitation data, EPSS score or NVD analysis exists yet. Recheck EPSS, KEV and the NVD status over the coming days.
- Debian 11 status is unclear. Upstream published 2.2.5 and the CVE record lists it as fixed for that branch, but the Debian tracker lists no bullseye package and the Extended LTS tracker could not be read (HTTP 403).
- Derivative distributions are described as affected but not named. No advisories from specific derivatives were found, so check each vendor directly.
- The sources do not say whether a malicious mirror serving over HTTPS can exploit the flaw. Ubuntu says TLS protects against the on-path case and separately says malicious mirrors can exploit the bug, without connecting the two. Our statement that HTTPS would not stop a malicious mirror is an inference.
- No vendor provides a reliable way to determine after the fact whether a swap happened. The checksum comparison leads come from secondary sources and have not been independently tested.
- Whether unattended-upgrades runs during an attack are exploitable in practice is not addressed by the sources. Our concern is an inference from the requirement for a package install and the shared download path.

Other notes

- Corrections to the briefing excerpt: Ubuntu now lists fixes for all eight tracked releases rather than vulnerable status, and vendor guidance does support temporarily setting Acquire::Retries to 0 [S6] [S8]. This report records an update date of 2026-11-05 because the CVE record and NVD entry changed that day [S2] [S12], and the briefing's 'No update' field should be read accordingly.
- Severity differs by source: the APT developers call the flaw critical, while Canonical assigns High and CVSS 4.0 7.7. The lower score reflects attack requirements and passive user interaction in the vector [S2] [S3]. This report uses High, matching the briefing.
- Sources describe the mechanism in different terms. Debian emphasizes merged downloads and improper file handling during resumption, while Canonical and the CVE record emphasize hard link reuse. The fix commit is consistent with both [S2] [S4] [S6] [S10].
- Debian testing status differs by time of reading. S1 and S16 describe forky as unfixed, while the tracker read on 2026-11-05 shows forky fixed in 3.3.6 [S1] [S9] [S16]. Confirm on the host before relying on either.
- Version strings need care. Ubuntu's 3.3.3ubuntu0.1 is a fixed backport even though it is numerically below upstream 3.3.6, so compare only within a release's own branch [S2] [S6].
- The same APT update also fixes several out-of-bounds memory access issues and a memory exhaustion issue, which the developers expect to have no impact beyond denial of service. Some apt-ftparchive out-of-bounds issues were left unfixed, which matters mainly for anyone building repositories from untrusted .deb files [S3].
- Max Justicz also reported CVE-2019-3462, an earlier APT redirect-injection bug, according to a single secondary source [S17].
- Red Hat's CVE page returned HTTP 404 and was not used. The Ubuntu CVE page's content matched S6 and is not listed separately.

CTI-20261105-01 v1.0 · Generated 2026-11-05 08:08 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.